

The State of ~~Cyber~~ Information Security Today

Jeff Man
InfoSec Curmudgeon
Paul's Security Weekly



whoami

Jeff Man

InfoSec Curmudgeon
Paul's Security Weekly

@MrJeffMan

301-310-4275

jeff@securityweekly.com



My Background

- **13 years with the Department of Defense**

- **Certified Cryptanalyst**
- **Designed Cryptosystems and Cryptologic Aids**
- **Founding Member of Systems & Network Attack Center**

- **20 years as a PCI Qualified Security Assessor (QSA)**

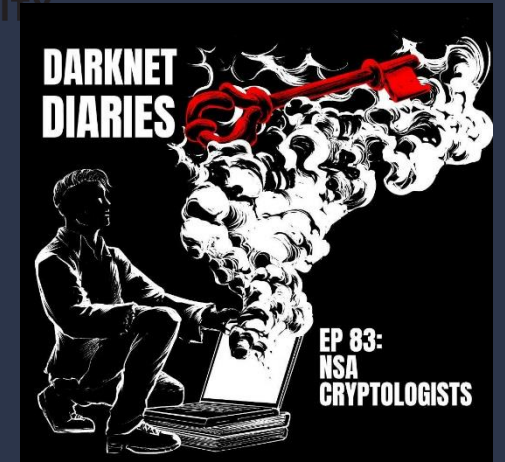
- **Lead Assessor/Assessment Team Member**
- **Trusted Advisor**

- **3 years with a Software Vendor**

- **PCI Subject Matter Expert**
- **Thought Leader**
- **Security Strategist**

- **30 years of commercial professional services**

- **Penetration Testing**
- **Vulnerability Assessments**
- **Security Architecture**



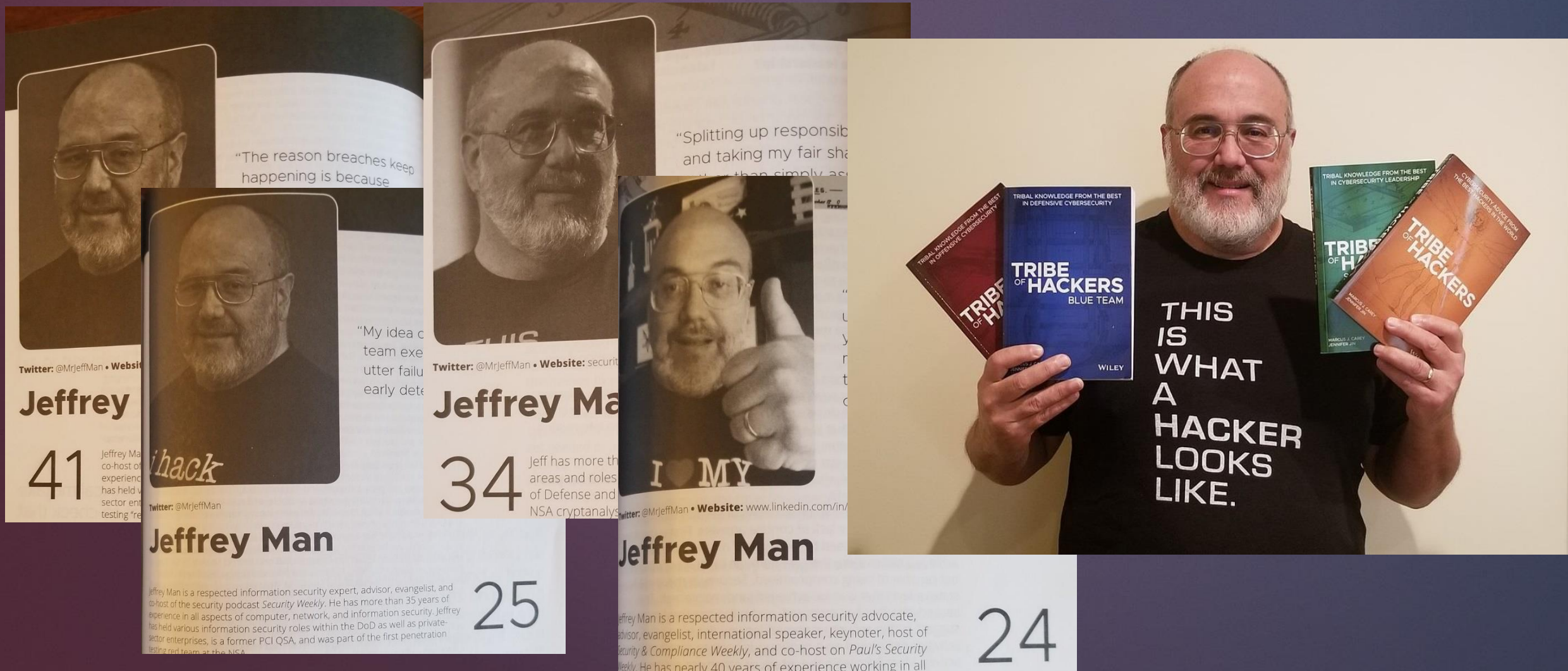


Not Used:
Too fancy,
Too colorful



Sunday, Monday, Tuesday, Wednesday, Thursday, Friday, Saturday, Funerals, Weddings, Date night, Speaking engagements

I'm a hacker (and I have the black hoodies to prove it!)



Four Time Contributor to the *Tribe of Hackers* series

EP 83: NSA CRYPTOLOGISTS

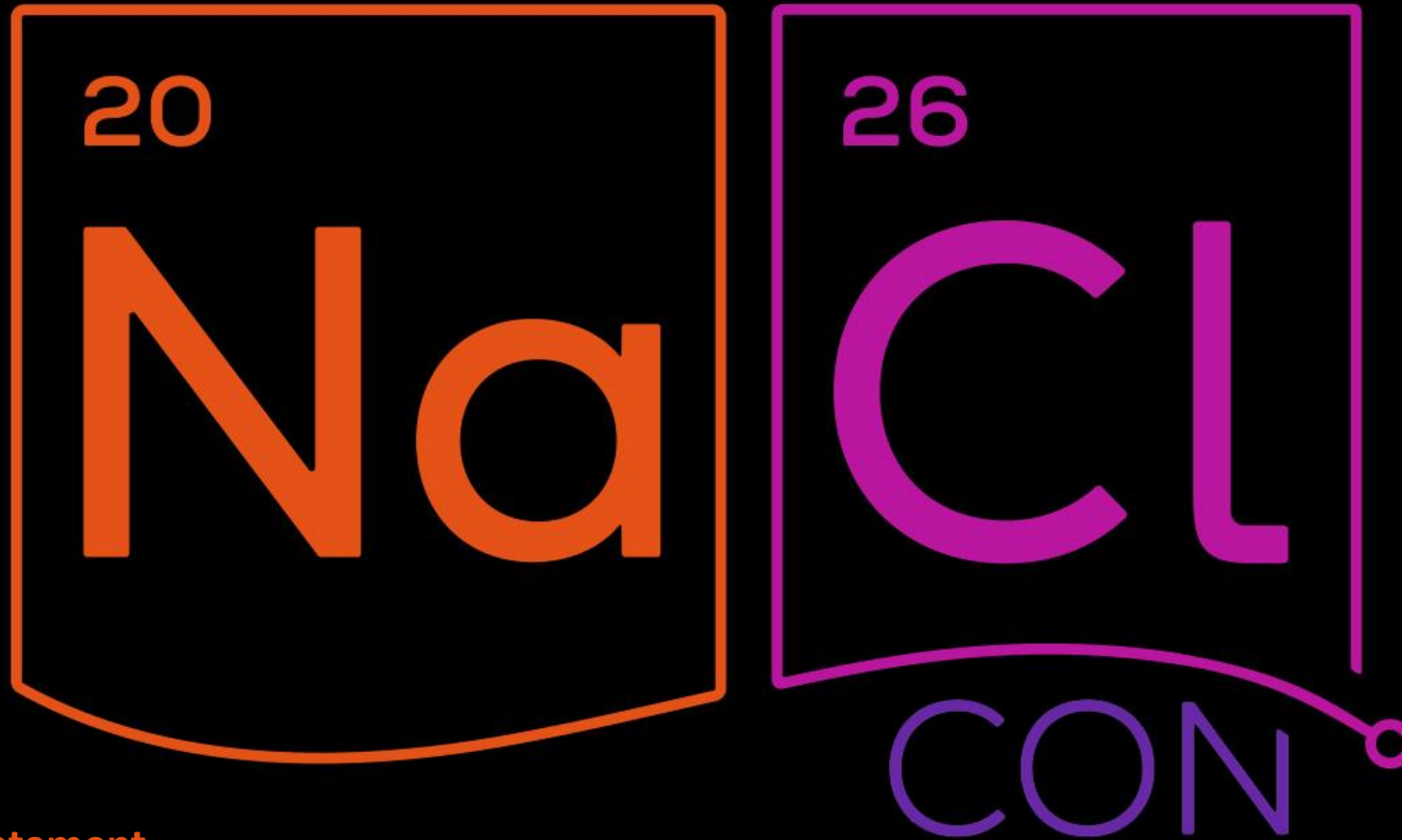
advanced persistent threat

19 January 2021 | 82:56



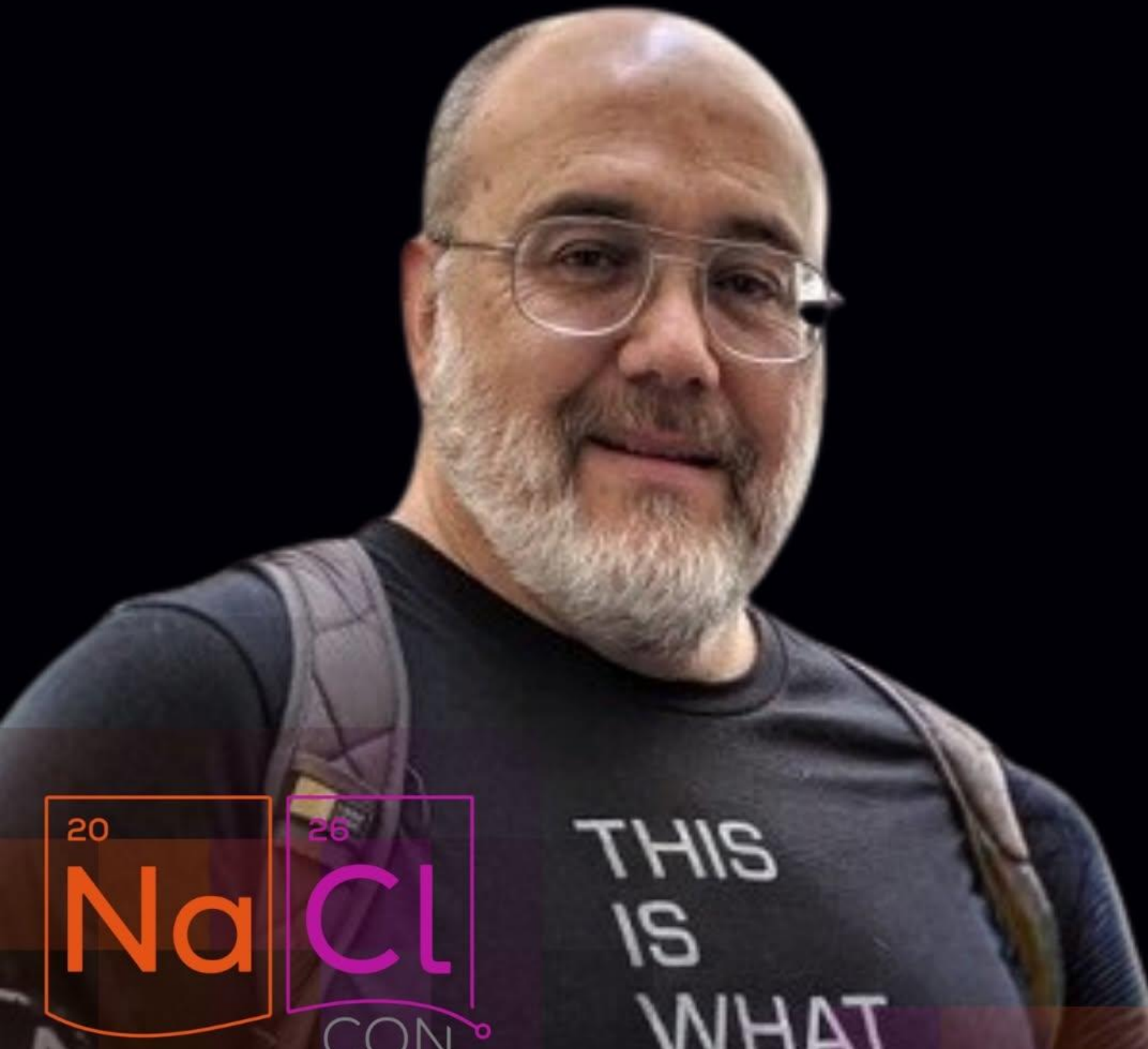


Member of the Cabal of the Curmudgeons



Mission Statement

We will host a intimate event at Carolina Beach dedicated to the History Of Hacking. We are bringing together world renowned experts in the field to share their stories that led to the foundation of the many groups, conferences, and sectors of the information security community. The mission of NaClCON is to provide a safe, inclusive, and technically rigorous forum for security practitioners, researchers, students, and community members to share knowledge, challenge assumptions, and advance the state of information security





May 3 · Carolina Beach, NC · 🌐

 **SPEAKER DROP** 

Some stories only exist behind closed doors.

Meet: Jeff Mann  Fireside Chat: Meanwhile at the NSA

With over 40 years in computer, network, and information security, Jeff Mann has seen—and helped shape—some of the most important chapters in cyber history.

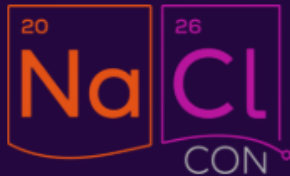
A Certified National Security Agency Cryptanalyst, Jeff designed and fielded the first software-based cryptosystem ever produced by the NSA and built the agency's first penetration testing red team.

From cryptography and forensic analysis to red teaming and national security, his career spans the government, military, and private sectors at the highest levels.

He's also the inventor of the "whiz wheel," a cryptologic cipher tool used by U.S. Special Forces for over a decade and now displayed at the National Cryptologic Museum.

This isn't theory. This is firsthand history.



[Home](#)[Event Registration](#)[Schedule](#)[Speakers](#)[Venue & Must Visits](#)[Local Community](#)[About NaClCON](#)[Sponsors & Partners](#)[Vendors & Villages](#)[FAQ's](#)[Get In Touch](#)[Media & Press](#)

Hacking

Chris Wysopal (Weld Pond)

Chris Wysopal (aka Weld Pond) was an early and longstanding member of L0pht Heavy Industries, the Boston-based hacker collective that turned a chaotic loft full of scavenged hardware into one of the most influential security labs of the early Internet. In the 1990s, he and his peers weren't working from textbooks or corporate playbooks—they were pulling systems apart, finding where they broke, and publishing what they found, whether vendors liked it or not.

At the L0pht, Chris was part of the crew that helped turn vulnerability research into something public and impossible to ignore. From cracking password systems to exposing fundamental flaws in widely deployed software, the group's work and tools like L0phtCrack forced a reluctant industry to confront the reality that insecurity wasn't an edge case, it was the default.

They rejected “security through obscurity” and instead made disclosure a lever to shift power, dragging uncomfortable truths into the open.

He was part of the L0pht team that testified before the U.S. Senate in 1998, delivering the now-infamous warning that they could take down the Internet in 30 minutes, a moment when hacker knowledge collided directly with national policy. After the L0pht era, Chris co-founded Veracode, helping bring application security into the enterprise, but his roots remain in that original scene: a time when a handful of hackers, working outside the system, forced the system to change.



"The Accidental Cyber Think Tank:

How the L0pht Forced the World to Take Software Security Seriously"



SECURITY

TALES

SEPT. 8
2018

FROM THE

3:00pm

CRYPT

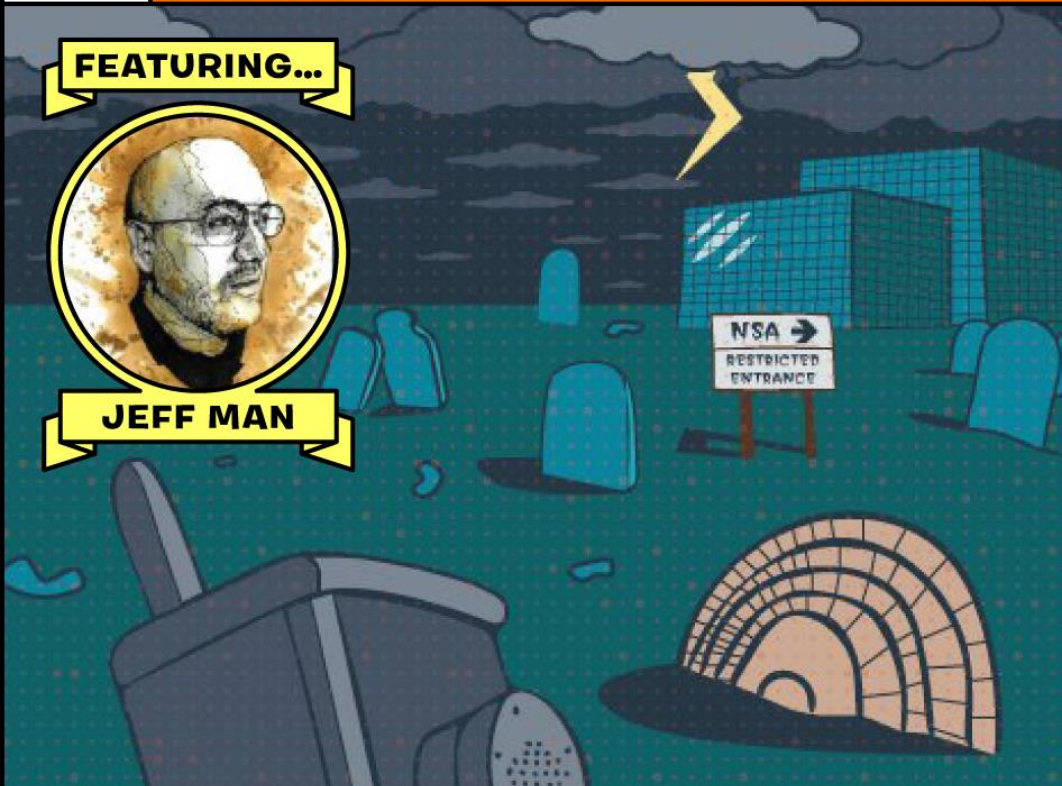
...ANALYST

CORNCON
IV

FEATURING...



JEFF MAN



I began my career as
a Cryptologist for NSA



National Security Agency



Professionalization Program

JEFFREY E. MAN

is hereby certified

AS A

CRYPTANALYST

by the

CRYPTANALYSIS CAREER PANEL

EFFECTIVE THIS 23RD DAY OF AUGUST 1993

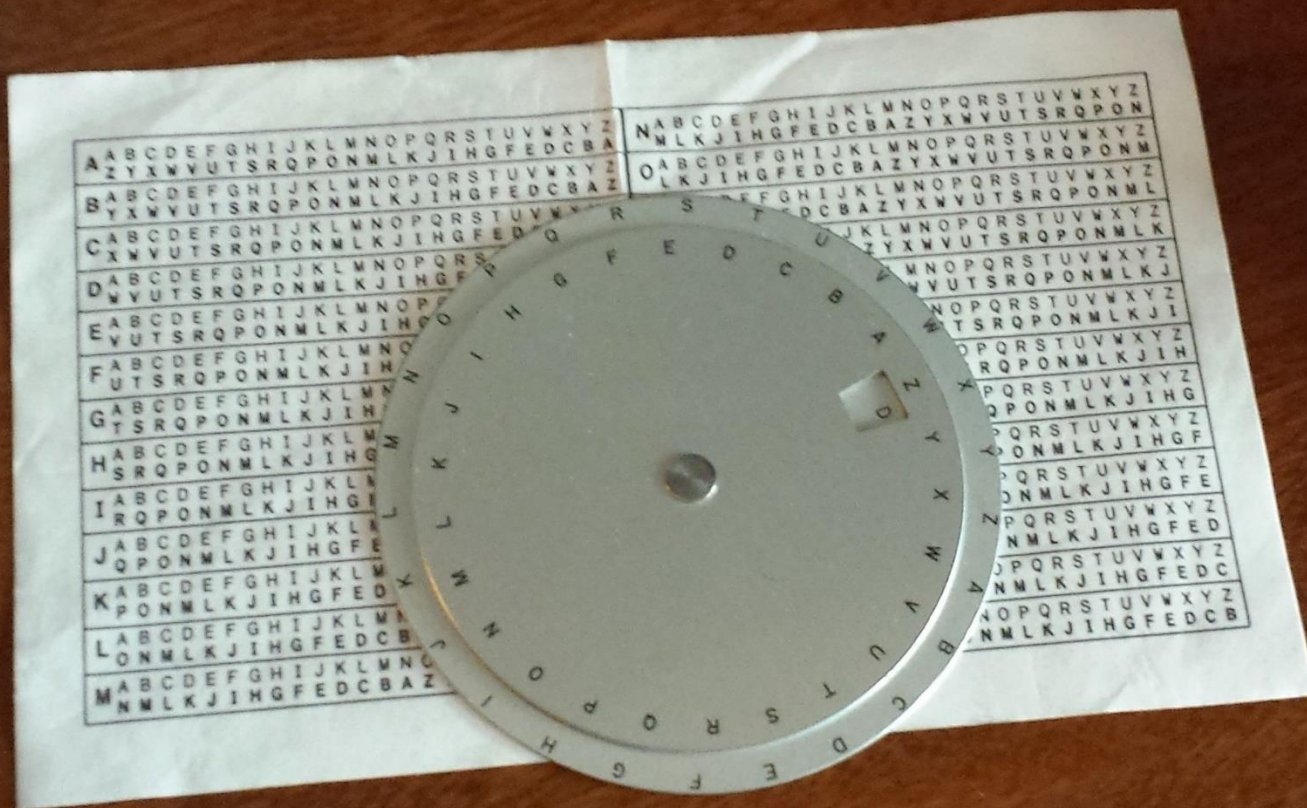
Panel Chairperson

J. M. McConnell
Vice Admiral, U.S. Navy
Director

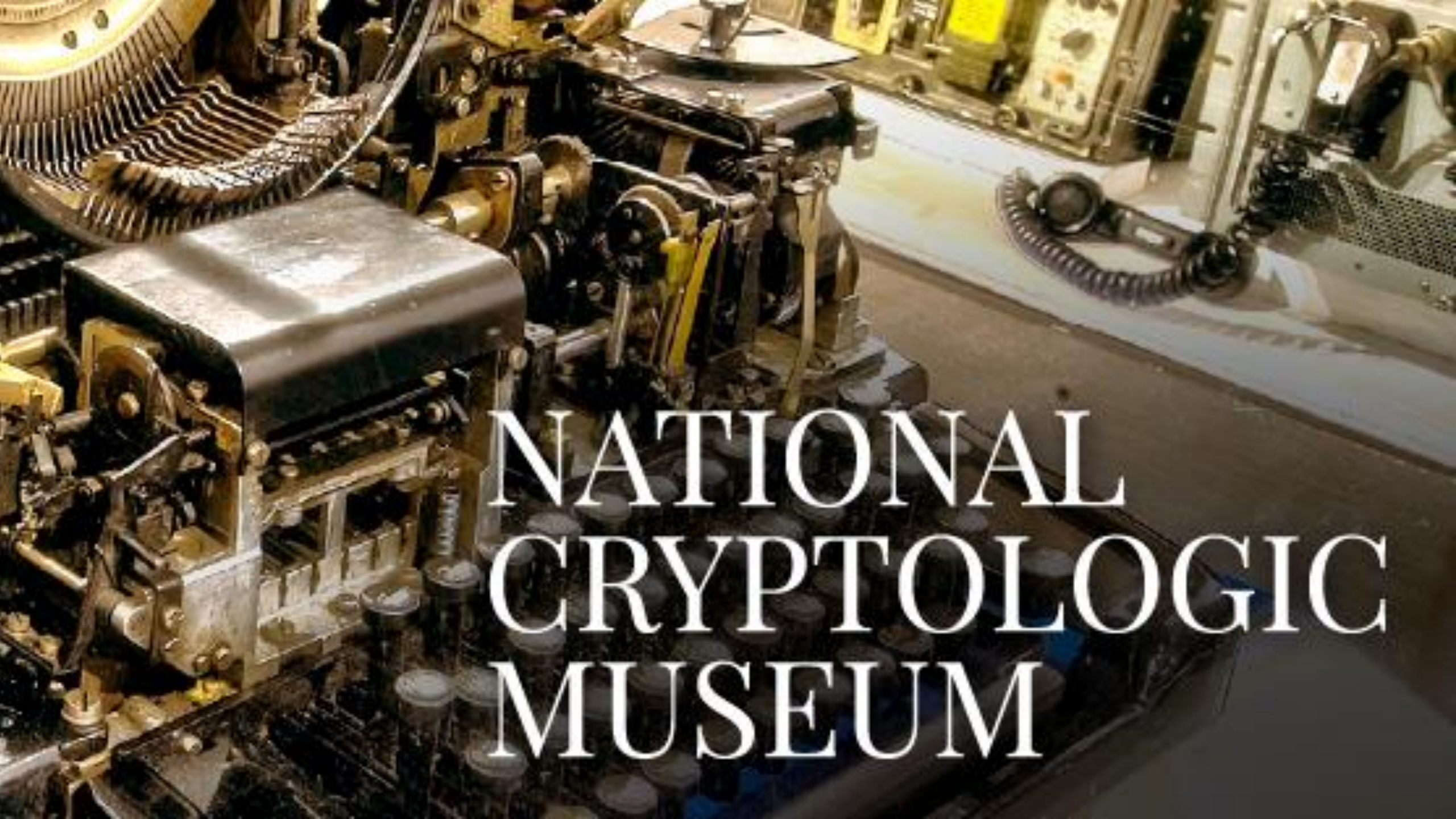
One-Time Pad



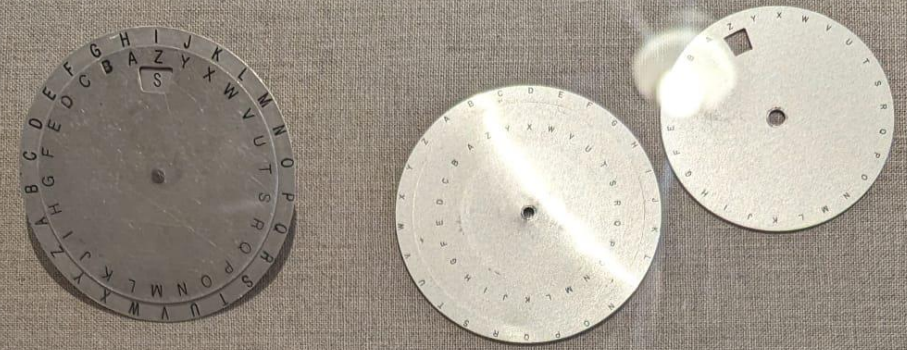
Designed and fielded NSA's First SW-Based Cryptosystem



The Vigenere "Wheel" – Specialized Cipher Disc



NATIONAL CRYPTOLOGIC MUSEUM



(Jeff) Man Reinvents the Wheel



Special operators get all the toughest jobs.
The most secret. The most important.
The most dangerous.

So NSA cryptanalyst Jeff Man thought he could make their work just a bit easier.

When units needed to send secret communications, they had to tediously cipher and decipher using one time pads. Man developed this HAL-001 Vigenere Wheel, more commonly known as the Whiz Wheel (yes, we know), to simplify the one time pad trigraph system of over one hundred 3-letter combinations. This cut down on time and chances for human error.

Less time spent on encryption/decryption, more time doing the stuff they would make movies about... in about 25 years or so...

HAL-001 Vigenere (Whiz) Wheel Prototype, Jeff Man, 1988

HAL-001 Vigenere (Whiz) Wheel Production Model, NSA, 1988

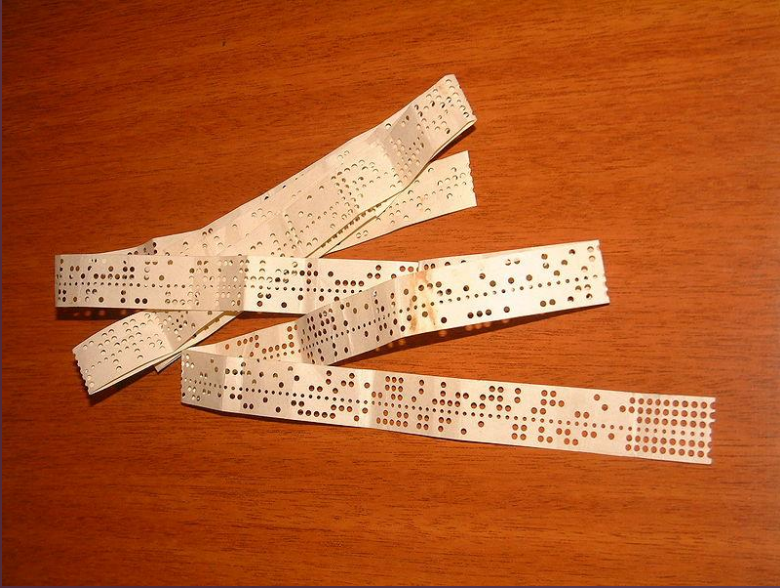
AN/GSC-62 Table Top Base Station



The AN/GSC-62 Lightweight Deployable Table Top Communications System (LDC TT), developed by SAI Technology, is a rugged, lightweight, transportable high frequency burst communications system. It augments the A/N TSC-99 base station by providing a rapidly deployable equivalent. The LDC TT is divided into four component groups; the message, the transmitter, the control and the receiver group. For more information, please contact SAI Technology at 800-447-4373 or 703-527-9400.

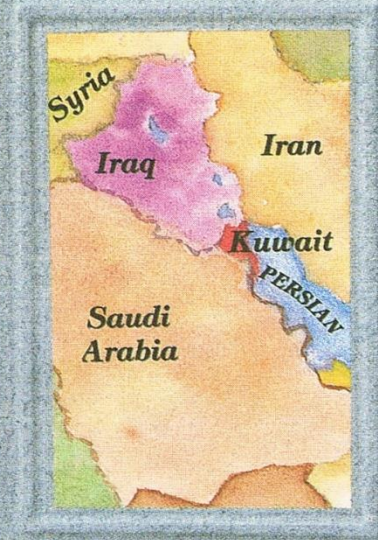
SAI **SAI Technology**
An Employee-Owned Company A Division of Science Applications
International Corporation

Modernization of US Special Operations Base Station (Numbers Station)



Hinged on replacing One-Time Tape (OTT) with One-Time Disc (OTD)

The first Gulf War 1990-1991



JUNE 1991

The National Security Agency/ Central Security Service

takes pleasure in presenting a Letter of Appreciation to

JEFFREY E. MAN

We want to convey our appreciation to you for your magnificent contribution to our fighting forces and the Nation during Operation Desert Shield/Storm. From the outset of Desert Shield and through the extremely successful completion of Desert Storm, you responded splendidly. Your dedication, perseverance, selflessness and professionalism were key factors in our victory.

**Pen
Testing
comes to
NSA**

**S
E
C
U
R
I
T
Y**

**MORE TALES
FROM THE
CRYPT
...ANALYST**

January 23, 1993

NCSA MOSAIC initial release (and the world changed)

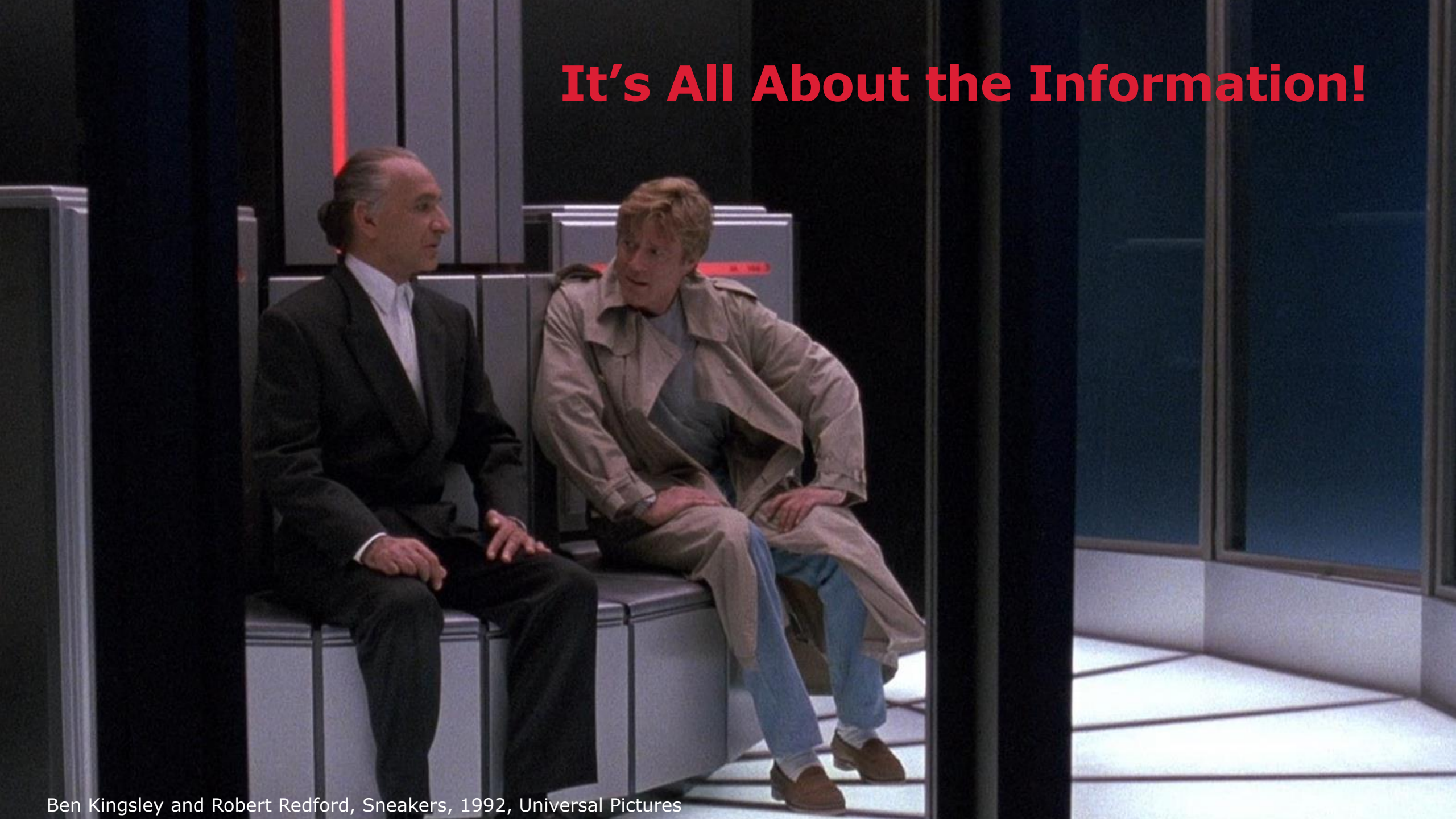


NSA "Red Team" Hacker | Jeff Man | Ep. 269

SNEAKERS



It's All About the Information!



Ben Kingsley and Robert Redford, Sneakers, 1992, Universal Pictures

DARK TERRITORY

THE
SECRET HISTORY
OF
CYBER WAR

FRED KAPLAN

AUTHOR OF *THE INSURGENTS*



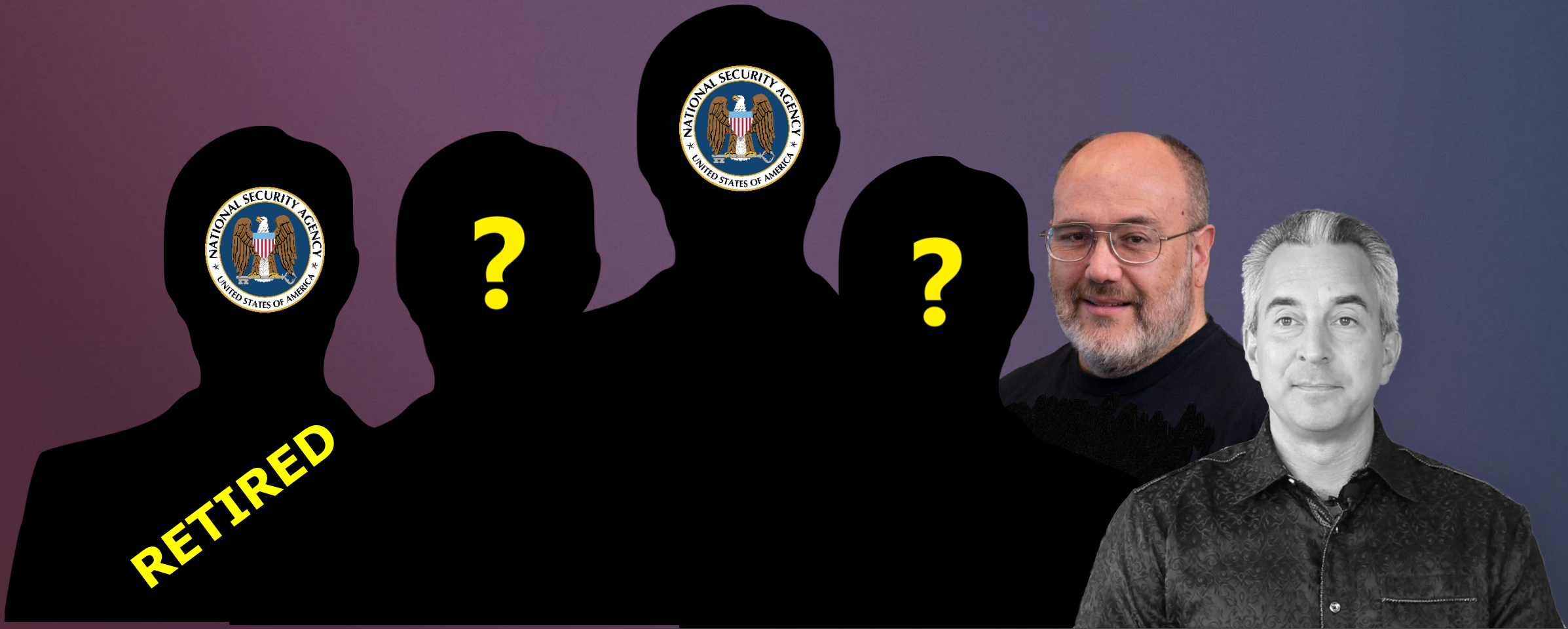
CONTENTS

CHAPTER 1	"Could Something Like This Really Happen?"	1
CHAPTER 2	"It's All About the Information"	21
CHAPTER 3	A Cyber Pearl Harbor	39
CHAPTER 4	Eligible Receiver	57
CHAPTER 5	Solar Sunrise, Moonlight Maze	73
CHAPTER 6	The Coordinator Meets Mudge	89
CHAPTER 7	Deny, Exploit, Corrupt, Destroy	107
CHAPTER 8	Tailored Access	119
CHAPTER 9	Cyber Wars	145
CHAPTER 10	Buckshot Yankee	171
CHAPTER 11	"The Whole Haystack"	191
CHAPTER 12	"Somebody Has Crossed the Rubicon"	203
CHAPTER 13	Shady RATs	221
CHAPTER 14	"The Five Guys Report"	237
CHAPTER 15	"We're Wandering in Dark Territory"	265

mander's personal computer, sending him false information, thus distorting his view of the battlefield and leading him to make bad decisions, which, in a real war, could have meant defeat.

The NSA had a similar group called the Red Team. It was part of the Information Assurance Directorate (formerly called the Information Security Directorate), the defensive side of the NSA, stationed in FANEX, the building out near Friendship Airport. During its most sensitive drills, the Red Team worked out of a chamber called The Pit, which was so secret that few people at NSA knew it existed, and even they couldn't enter without first passing through two combination-locked doors. In its workaday duties, the Red Team probed for vulnerabilities in new hardware or software that had been designed for the Defense Department, sometimes for the NSA itself. These systems had to clear a high bar to be deemed secure enough for government purchase and installation. The Red Team's job was to test that bar.

Minihan's idea was to use the NSA Red Team in the same way



The Pit – was really a team of hackers

Copyright 1998 Indigo Publications

Intelligence Newsletter

September 17, 1998

SECTION: BUSINESS INTELLIGENCE; UNITED STATES; N. 342

LENGTH: 523 words

HEADLINE: The Hidden Cost of Asking NSA's Help

BODY:

The National Security Agency is being asked increasingly by the government's civilian branches to simulate attacks on their computer systems to evaluate threats even though such tests are in blatant contravention of the country's Computer Security Act, according to officials in Washington. The law assigns responsibility for threat assessments to the National Institute of Standards and Technology (NIST), a civilian agency, and not to NSA, an intelligence organization that answers to the Pentagon.

The practice has stirred concern among many who are familiar with NSA's methods of eavesdropping and breaking into computer systems and who underline the danger of giving the NSA access to systems containing intimate personal details of millions of American citizens, and to many financial institutions and companies.

Word got out. We were in demand.



NATIONAL SECURITY AGENCY
FORT GEORGE G. MEADE, MARYLAND 20755-6000



21 August 1996

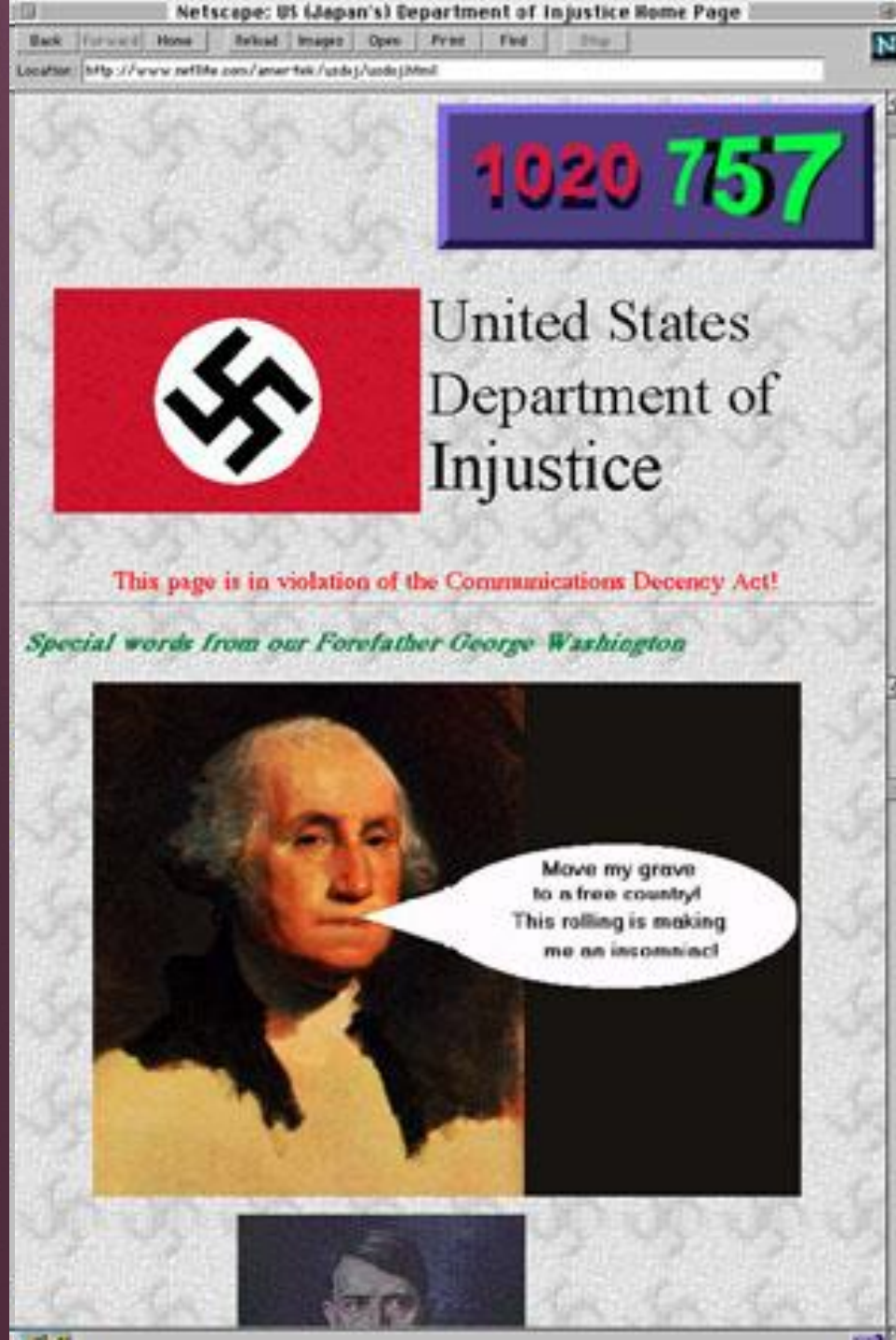
MEMORANDUM FOR ASSISTANT SECRETARY OF DEFENSE FOR COMMAND,
CONTROL, COMMUNICATIONS, AND INTELLIGENCE

SUBJECT: Testing the Vulnerability of the Department of Justice Sensitive
Computer Systems - INFORMATION MEMORANDUM

This is in response to the letter from the Attorney General, dated 30 July 1996, formally requesting that NSA support a vulnerability assessment of the security posture of the Department of Justice (DOJ) sensitive computer systems and networks. NSA accepts the request to support DOJ's efforts, beginning with the testing and evaluation of the security configurations in the Financial Management Information System (FMIS).

Analysts from our Systems and Network Attack Center (SNAC) are prepared to conduct "insider" penetration testing this month in accordance with the provisions of the National Telecommunications and Information Systems Security Directive (NTISSD) No. 600, Communications Security (COMSEC) Monitoring, to evaluate the effectiveness of the security configurations in the target DOJ network. The point of contact for this effort is Mr. Jeffrey Man, [REDACTED]

KENNETH A. MINIHAN
Lieutenant General, USAF
Director, NSA



**But then this
happened...**

August 17, 1996





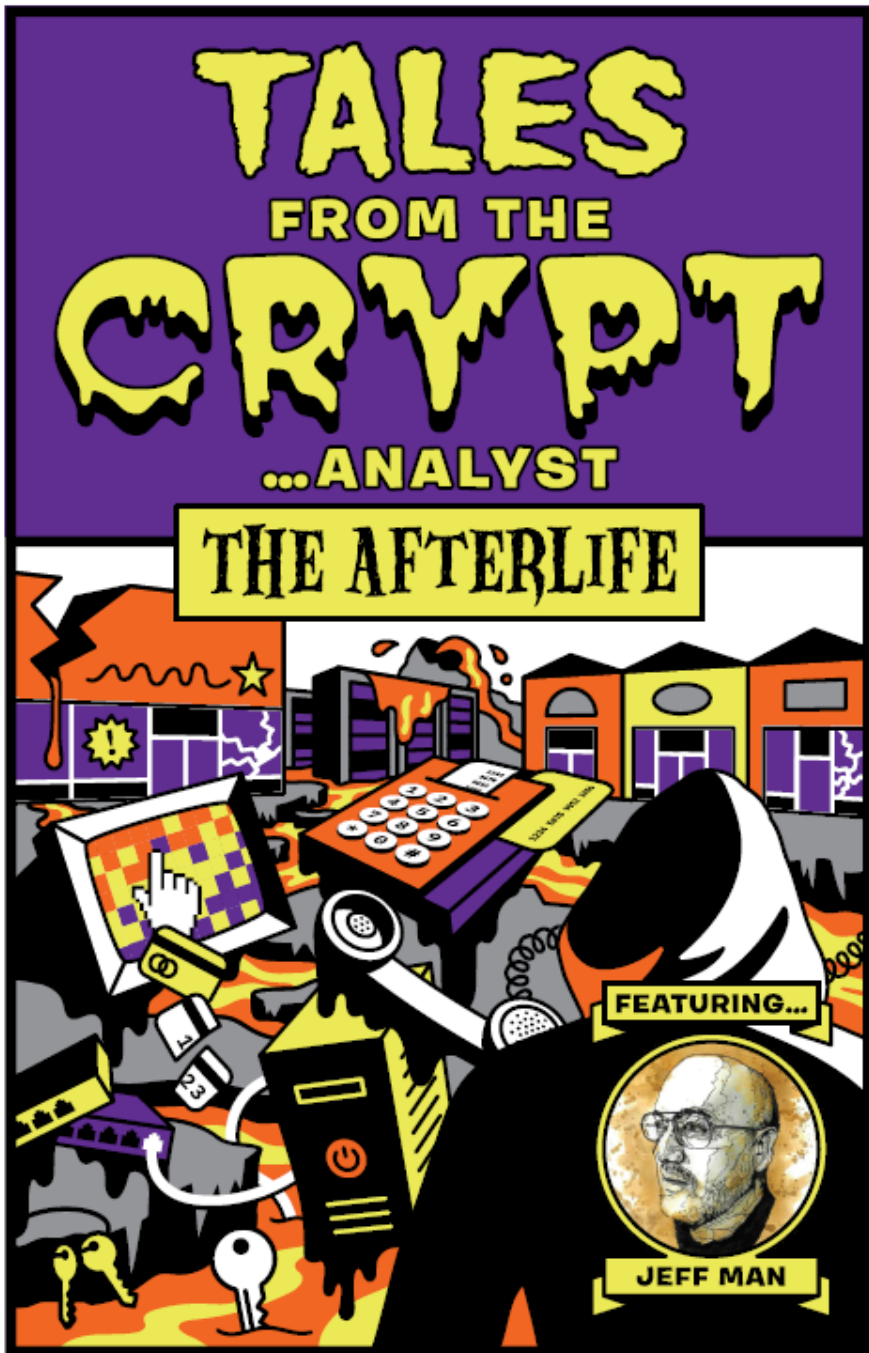
I was put on double secret probation!



**By the end of
September I
was gone**



Summary of my NSA Career



Thus started
my
adventures in
the private
sector

The Incentives Didn't Change

1998

Ship now

Patch later

No liability

2026

Ship with AI faster

Patch later

No liability



**What we were
saying in 1998**



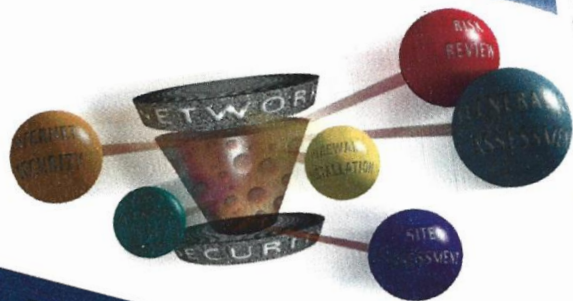
Nichols Research
Information Security Group
1997-1999

FIREWALL INSTALLATION

Order No. 97003

Nichols
Research

Network Security Solutions



If your en-
you are p
Internet
ideal r
work
semi

SECURITY RISK REVIEW

Network Security Solutions

One of the most cost-effective ways to improve a security program is with a risk review. Following the adage that what you don't know can harm you, a review will produce a wealth of practical information which an organization can use to mitigate vulnerabilities found in its information systems. Even for organizations with security programs in place, an external review offers the benefit of experts assessing the information system in much the same way an accounting audit independently evaluates an organization's accounting practices.

A Successful Engagement is a Partnership

A risk review is structured to provide a snapshot security review of a well-defined security issue, specific threat, or specific vulnerability to determine its significance and impact. Performing a risk assessment is especially appropriate for organizations considering adding a connection to the Internet, establishing a public web server, offering secure remote access, or offering a trusted partner access to an internal network.

Nichols Engagement Philosophy

Nichols' approach to its information protection engagements is to improve the security of the client's information systems and networks. In the case of a risk review, Nichols cannot produce a quality deliverable without the full cooperation and assistance of the client's IS staff. Although the Nichols Team will provide management with an unbiased and objective report, the team strives to produce a balanced report in which equal emphasis is placed on the successful security programs in place as well as recommended improvements. This process starts during the engagement kickoff meeting when the Nichols Security Team meets with the client.

first line

FIREWALL PLANNING & SELECTION

Order No. 97002

Nichols
Research

Network Security Solutions

If you are considering putting your enterprise on the Internet, you are probably already thinking about firewalls. A firewall is your corporation's first line of defense for protecting its valuable information assets. But what else can a firewall help accomplish?

The new...

VULNERABILITY ASSESSMENT

Order No. 97005

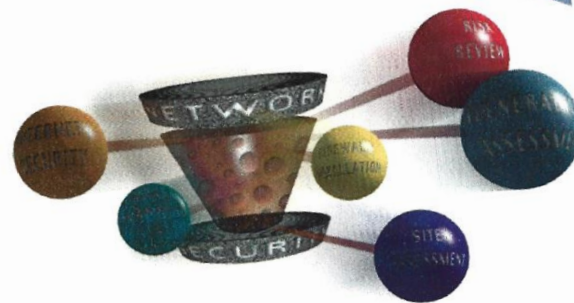
Nichols
Research

Network Security Solutions

One of the most effective methods to improve the security of your enterprise network is to examine your current security posture through a Vulnerability Assessment. A Vulnerability Assessment identifies existing weaknesses in your network architecture, configuration, and administration practices. Nichols' Network Security Engineers use a three-phased approach designed to

- Present a cost-effective solution to satisfy your security needs.
- Assess your organization's overall security posture in relation to existing security policies.
- Identify existing vulnerabilities in your network.

Deliverables Results of the assessment are documented in a Final Report. The report includes a summary of findings, analysis of organizational weaknesses, and a detailed listing of vulnerabilities and recommended security measures that corre-



Though designed to function optimally as a whole, each of the three individual phases delivers unique and valuable information. We will work with you to determine your needs and tailor an approach that best satisfies your security requirements.

Prerequisites A successful Vulnerability Assessment is achieved only if the customer already has some form of a security plan and/or policy in effect. Each phase of the assessment carries with it specific rules and guidelines that govern the work to be performed.

The Need for Security

- **Information and Computing Resources Are Vital Assets**
- **Loss or Misuse Represents Significant Risk**
- **Potential Consequences:**
 - Disclosure of Sensitive or Regulated Information
 - Loss of Competitive Advantage and/or Potential Revenues
 - Reduction in Productivity
 - Lost Business Due to Disruption in Operations
 - Bad Publicity and/or Damage to Corporate Reputation
 - Liability Damages

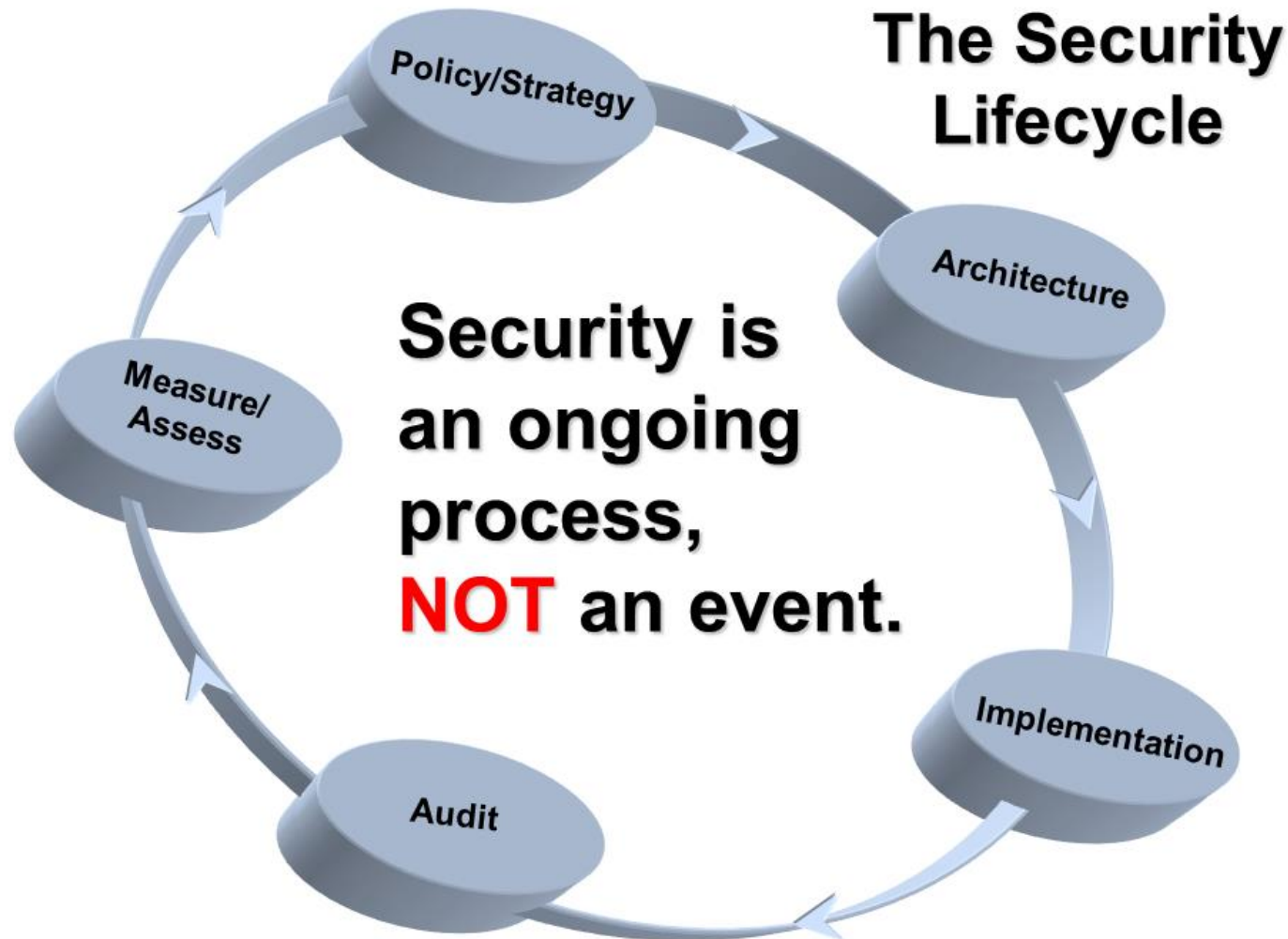
What Makes a Network Insecure?

- **No Written Corporate Security Policy**
- **Lack of Commitment to Security**
 - Awareness
 - Management Often in State of Denial
 - End User Ignorance
 - Resources: People, Money, Time
- **Decentralized Administration - Lack of Coordination**
 - Matrixed Management Means No One Is Responsible or Accountable
 - Responsibility Not Matched With Authority

THE SOLUTION

What needs to be done

Understanding Security



The Security Lifecycle

- **Security Requires a Systematic Approach**
 - Assess Where You Are Today
 - Document Where You Want to Go
 - Implement a Security Architecture
- **The Policy Is the Strategy**
- **The Architecture Is the Coherent, Integrated Set of Tactics by Which the Policy Is Carried Out**
- **Security Without Policy Is Simply Technology**

What is an Information Security Policy?

- **Defines Information Security Objectives and Priorities**
- **Statement of Management Expectations (the “What”)**
- **Defines Responsibility for Protecting Assets**
- **Serves As Foundation for All Security Efforts**
- **Provides Justification for:**
 - Controls/Products to be Implemented
 - \$ Spent on Security
 - Impact Imposed on End Users
- **Designed to Enable Business**

What an Information Security Policy is NOT

- **Burdensome List of Irrational Restrictions**
- **Configuration Rules for Firewall**
- **Cumbersome Document Collecting Dust on Shelf**
- **Procedures, Standards, Guidelines:**
 - Written to Support Policy
 - Detailed Step-by-Step Descriptions of How a Job Is Done (the “How”)
- **Acceptable Use Statements:**
 - Standards for Asset Utilization
 - Stress Individual Responsibility

The Business Case

- **Leverages Future Security Investment**
 - Focus on Critical Information Assets
 - Protection Commensurate With Value
- **Raises Security Awareness Among Employees**
- **Plays Critical Role in Liability Abatement**
 - Demonstrates Due Diligence Regarding Protection of Assets
 - Limits Liability Resulting From Employee Actions
- **Supports Compliance With Legal Requirements to Protect Data (i.e., Privacy Act)**

The Business Case

- **Provides Framework for:**
 - Consistent, Timely, and Cost-effective Management Decisions
 - Selection of Security Controls and Products
 - Defining and Empowering Acceptable Employee Behavior
 - Empowering Employees to Perform their Jobs Securely
- **Simplifies Mergers and Acquisitions.**
- **Technology Helps, But....**
 - “You Can’t Solve Social Problems with Software.”

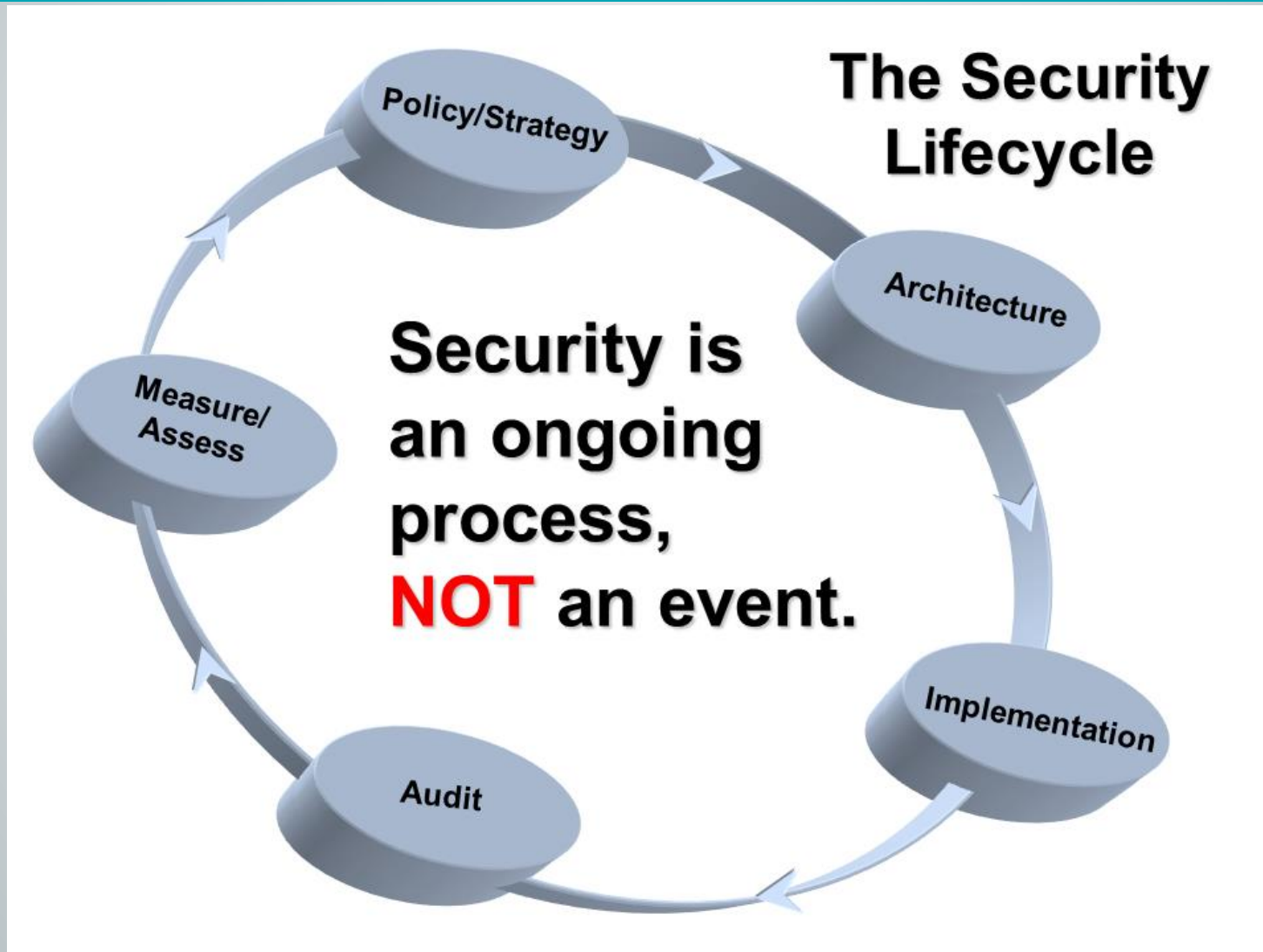
Policy Pitfalls: Why Policy Efforts Fail

- **Insufficient Resources to Complete Effort**
- **Policy Is Developed in Vacuum or by Decree**
- **Policy Does Not Reflect Security Needs or Risk Profile**
- **Policy Is Not Supported by Senior Management or Made Sufficiently Visible**
- **Policy Is Too Cumbersome and Legalistic**
- **Lack of Enforcement Makes Policy Meaningless**
- **Focus of Policy Misplaced on Technology, Not on People**

Keys to Success

- **Understand the Corporate Culture:**
 - Different Levels of “Risk Tolerance”
 - Working Within Your Organizational Structure
- **Solicit Input from Representatives from Key Business Areas**
- **Management Must Lead - “Walk the Talk”**
- **No Sacred Cows Allowed**
- **Policy Is Clearly Defined, Realistic, Consistent and Documented**
- **Policy Distribution Is Supported With Training**

For Everything There is a Season



The need for security got
real on 9/11



**What we were
saying in 2002**



META Security Group
1999 - 2004

The Five Worst Security Mistakes End Users Make

- 
- 
- 
- 
- 
- 1. Opening unsolicited e-mail attachment without verifying their source and checking their content first.**
 - 2. Failing to install security patches-especially for Microsoft Office, Microsoft Internet Explorer, and Netscape.**
 - 3. Installing screen savers or games from unknown sources.**
 - 4. Not making and testing backups.**
 - 5. Using a modem while connected through a local area network.**



The Seven Worst Security Mistakes Senior Executives Make

1. Assigning untrained people to maintain security and providing neither the training nor the time to make it possible to learn and do the job.
- ➔ 2. Failing to understand the relationship of information security to the business problem-they understand physical security but do not see the consequences of poor information security.
3. Failing to deal with the operational aspects of security: making a few fixes and then not allowing the follow through necessary to ensure the problems stay fixed.
- ➔ 4. Relying primarily on a firewall.
5. Failing to realize how much money their information and organizational reputations are worth.
6. Authorizing reactive, short-term fixes so problems re-emerge rapidly.
- ➔ 7. Pretending the problem will go away if they ignore it.

The Ten Worst Security Mistakes Information Technology People Make

- 
1. Connecting systems to the Internet before hardening them.
 2. Connecting test systems to the Internet with default accounts/passwords
 3. Failing to update systems when security holes are found.
 4. Using telnet and other unencrypted protocols for managing systems, routers, firewalls, and PKI.
 5. Giving users passwords over the phone or changing user passwords in response telephone or personal requests when the requester is not authenticated.
 6. Failing to maintain and test backups.
 7. Running unnecessary services, especially ftpd, telnetd, finger, rpc, mail, rservices.
 8. Implementing firewalls with rules that don't stop malicious or dangerous traffic-incoming or outgoing.
 9. Failing to implement or update virus detection software
 10. Failing to educate users on what to look for and what to do when they see a potential security problem.

And a BONUS, number 11: Allowing untrained, uncertified people to take responsibility for securing important systems.

Where do we stand today?

What's working, what's not, and why?
What can we do about it?

Threats

Disgruntled, Former and Temporary Employees

Hackers

Industrial Espionage

The Media

Criminal Activity

Natural Events and Accidents

Blunders, Errors, Omissions

Terrorists

National Intelligence

Motives

Access to Data

Disrupt Operations

Steal \$\$, Products, or Services

Obtain Free Use of Resources

Visibility, Publicity, Chaos

Embarrass Target, Retribution

Thrill, Challenge

Competitive Advantage

What are today's threats?

Humanity is technologically
connected but institutionally
divided

- Firewalls
- IDS/IPS
- Anti-Virus
- Whitelisting
- Access Controls
- SIEM
- VPNs
- Two-Factor Authentication
- Encryption
- Scanning
- Penetration Testing
- WAFs
- Password Vaults
- Cloud



Too Many Solutions

- **Information and computing resources** are vital assets
- **Loss or misuse** represents significant risk
- **Potential consequences:**
 - Disclosure of sensitive or regulated information
 - Loss of competitive advantage and/or potential revenues
 - Reduction in productivity
 - Lost business due to disruption in operations
 - Bad publicity and/or damage to corporate reputation
 - Liability damages

The Need for Security

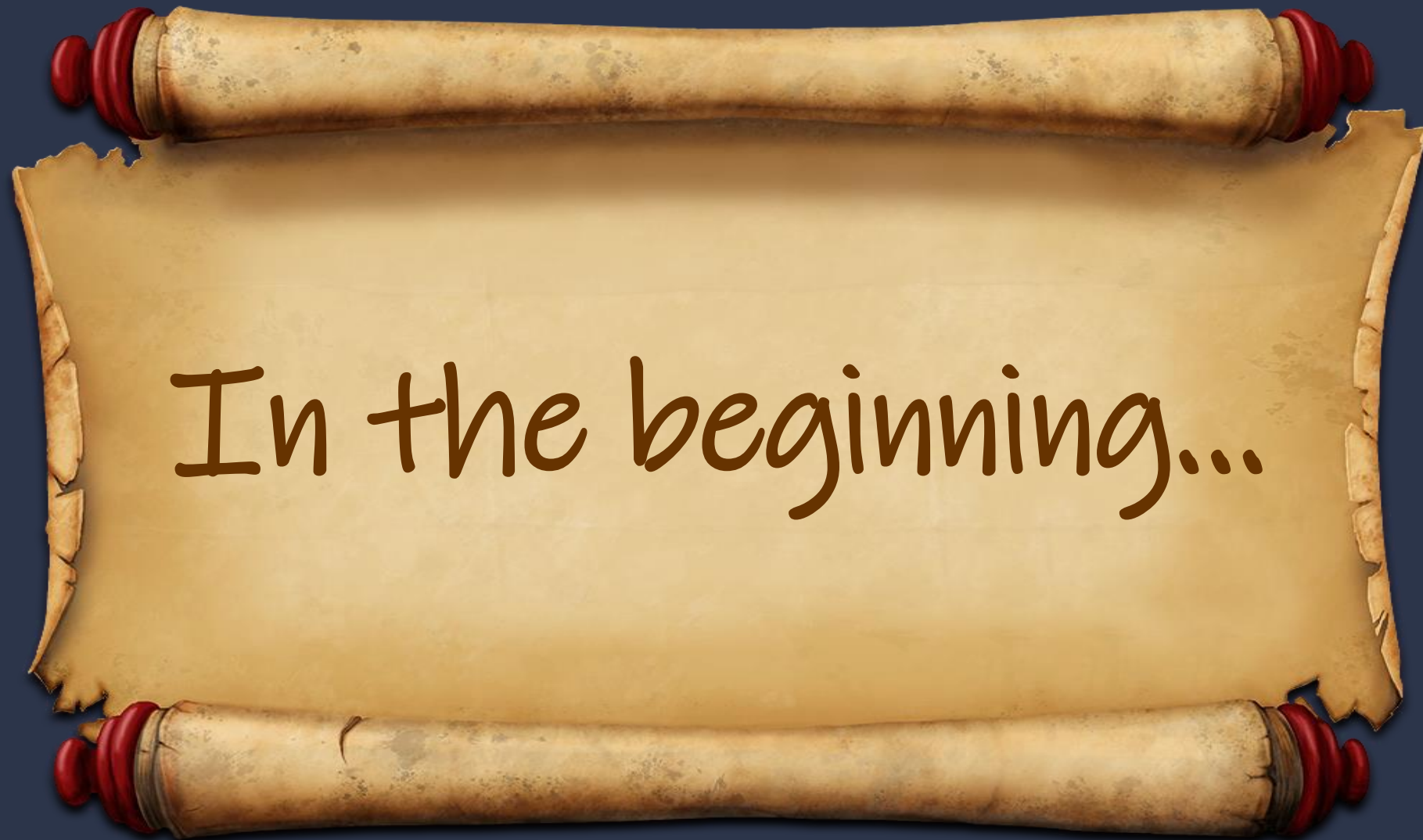
- **No written corporate security policy**
- **Lack of commitment to security**
 - Awareness
 - Management often in state of denial
 - End user ignorance
 - Resources: people, money, time
- **Decentralized administration – lack of coordination**
 - Matrixed management means no one is responsible or accountable
 - Responsibility not matched with authority

What Makes a Network Insecure?

What can we learn from the past

What needs to be done





In the beginning...



This was the extent of data security



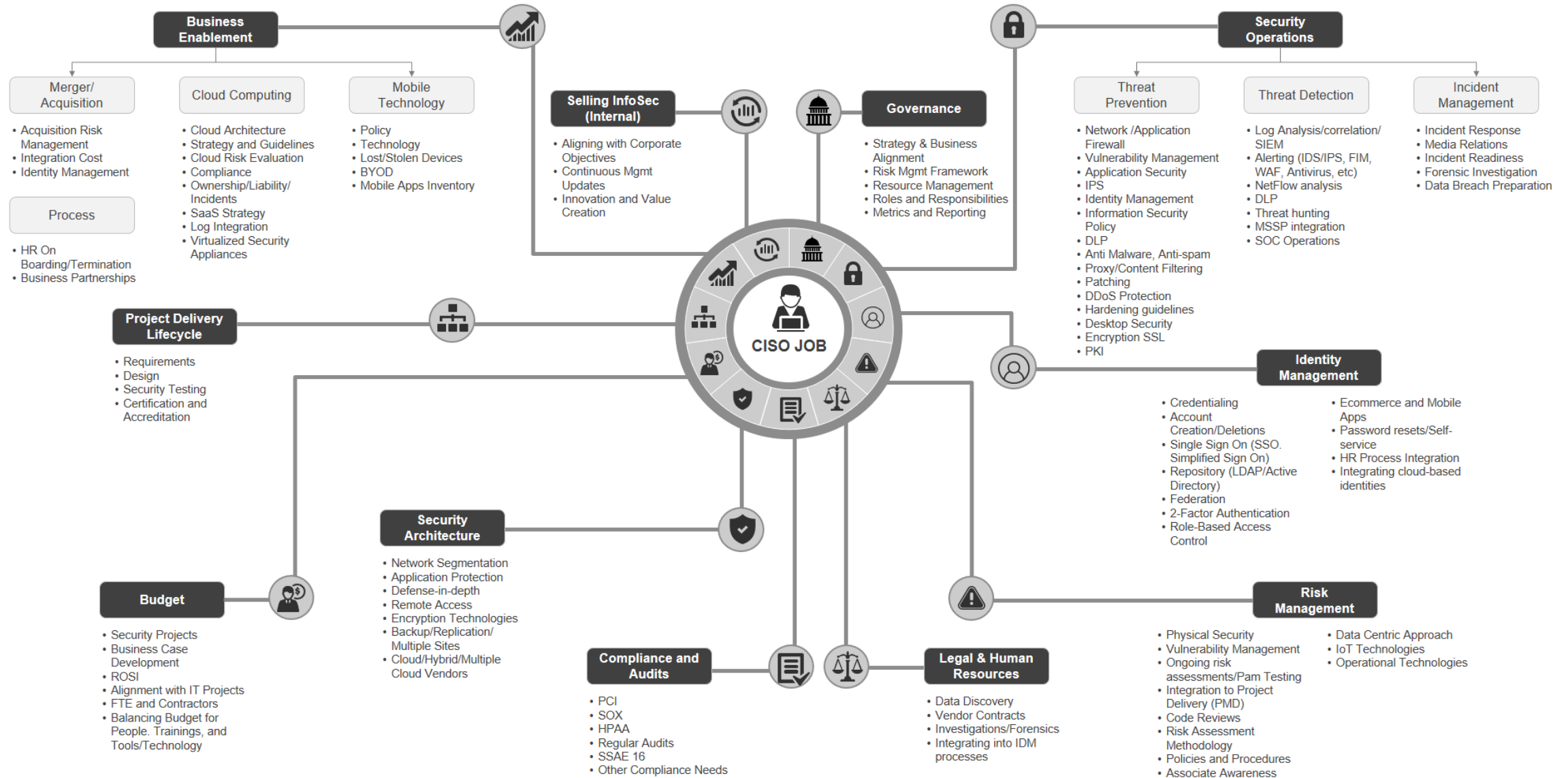
Codes & Ciphers

And this is how we shared secrets

Espionage



CISO Mind Map



CISO Periodic Table

Security concerns of the modern-day CISO

 Click each element to learn more

Dx Digital Transformation	Ba Business Alignment							Ot Operational Technology	Trm Third-Party Risk Mgmt	Ra Role & Accountability	Mi Malicious Insiders
Go Governance	Cm Change Management	Cfg Configuration Management				Rs Resilience	Cti Cyber Threat Intelligence	Sas Secure Access Service Edge	Dso DevSecOps	Bu Budget	Ni Negligent Insiders
Rm Risk Management	Bd Big Data	Iam Identity & Access Mgmt	Pt Penetration Testing	Tm Threat Management	Ns Network Security	Si Security Info & Event Mgmt	Zt Zero Trust	Th Threat Hunting	Bc Blockchain	St Staffing	Oc Organized Crime
Co Compliance	MI Machine Learning	Am Asset Management	Es Endpoint Security	As Application Security	Vm Vulnerability Management	Soc Security Operations Ctr	Ai Artificial Intelligence	Fc Fusion Center	We Web3	Te Technology	Nt Nation State
Pr Privacy	Pm Patch Management	Em Email Management	Ws Web Security	Cs Cloud Security	Dp Data Protection	Ir Incident Response	Dr Detection & Response	Oa Orchestration & Automation	Np Natural Lang Processing	Oz Optimization	Ha Hacktivist

 Business Fundamentals
 IT Fundamentals

 Security Program Fundamentals
 Advanced Security Programs

 Emerging Technology

 CISO Constraints
 Threat Actors

Everything I learned about INFOSEC I learned at NSA

(I'm pretty sure we started it)



**“What can be created
by man can be broken
by man.”**

– NSA Chief Scientist

Data Security

▀ Confidentiality

- ▀ Stealing Data
 - ▀ Local (System, Application)
 - ▀ Network (Repositories)

▀ Integrity

- ▀ Fraud
 - ▀ Altering legitimate data
 - ▀ Using previously stolen data
 - ▀ Identity theft

▀ Availability

- ▀ Denial of Service
- ▀ Ransomware



Risk Parameters

▀ Vulnerabilities (weaknesses)

- ▀ Bugs/Features
- ▀ Misconfigurations
- ▀ Processes
- ▀ People

▀ Threats (badguys)

- ▀ Data thieves
- ▀ Fraudsters
- ▀ Nation States

▀ Countermeasures (mitigation)

- ▀ Detection
- ▀ Response
- ▀ Recovery

Risk-Based Security Model



UNCLASSIFIED

NSTISSI No. 4009
September 2000



**NATIONAL INFORMATION
SYSTEMS SECURITY
(INFOSEC)
GLOSSARY**

THIS DOCUMENT PROVIDES MINIMUM STANDARDS. FURTHER IMPLEMENTATION
MAY BE REQUIRED BY YOUR DEPARTMENT OR AGENCY.

UNCLASSIFIED

Everything you
ever wanted to
know about
InfoSec...and it's
online these days!

RISK

Possibility that a particular threat will adversely impact an information system by exploiting a particular vulnerability.

THREAT

Any circumstance or event with the potential to adversely impact an information system through unauthorized access, destruction, disclosure, modification of data, and/or denial of service.

VULNERABILITY

Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited.

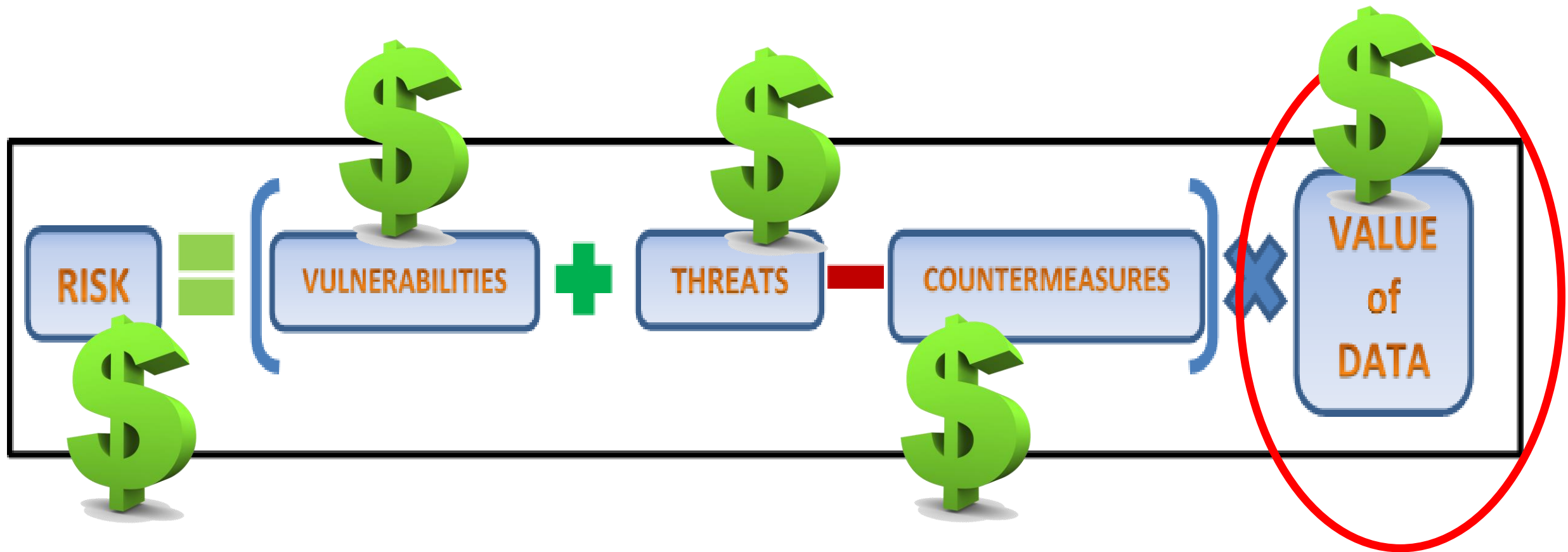
COUNTERMEASURE

Action, device, procedure, technique, or other measure that reduces the vulnerability of an information system.

Risk-Based Security Model



Risk-Based Security Model



The Security Life Cycle

- Starts with knowing what you're protecting
- Security Requires a Systematic Approach
 - Assess Where You Are Today
 - Document Where You Want to Go
 - Implement a Security Architecture
- The Policy Is the Strategy
- The Architecture Is the Coherent, Integrated Set of Tactics by Which the Policy Is Carried Out
- Security Without Policy Is Simply Technology

We Haven't Always Helped

- Customers just want the “solution”
 - Pay less or bare minimum
 - Don't outrun the bear...outrun your friend
 - Where do I put the machine with the blinky lights?
 - Security is someone else's responsibility
- Vendors run the industry
- Too much focus on technology
- Too much emphasis on vulnerabilities
- ...and penetration testing (there, I said it)
- Nobody knows the difference between risk and threat

**Curmudgeon
To Do List:**

- ☒ Coffee
- ☐ No
- ☐ Get Off My
Lawn

**So what's
bothering me?**

- Cybersecurity
- Use Case
- “Built-in vs. Bolted-on”
- Solutions
- New Risk
- Potential Vulnerability
- 0-Day
- APT
- MFA
- Quantum/Post-Quantum
- Nation State
- Compliance
- Potential Threats
- Zero Trust
- Risk Tolerance
- Digital Resilience
- ROI
- Automation
- Scope
- Agentic AI

Triggering Words/Phrases

YOU KEEP USING THAT WORD.

**I DO NOT THINK IT MEANS WHAT YOU
THINK IT MEANS**

Threat(s)	Context(ual)	ML & AI	Discover(y)	Real-time
Cyber	Insights	Seamless(ly)	Comprehensive	Simplify
Intelligence	Scalable	AUTO- MATION	Actionable	"Platform"
Deep	Orchestrated	Empower(s)	Prioritization	Behavioral
Visibility	Workflow	Advanced	Unknown	Continuous(ly)

B I N G O

Encryption	Zero Trust	DDoS Attack	VPN	Blockchain
AI-Driven Security	Cloud Security	Phishing	IoT Security	Threat Intelligence
Big Data	MFA	Free!	End-to-End Encryption	Cyber Espionage
SOC	Cyberattack	Dark Web	Machine Learning	Next-Gen
Ransomware	Hacker	Cyber Resilience	APT	Endpoint Security

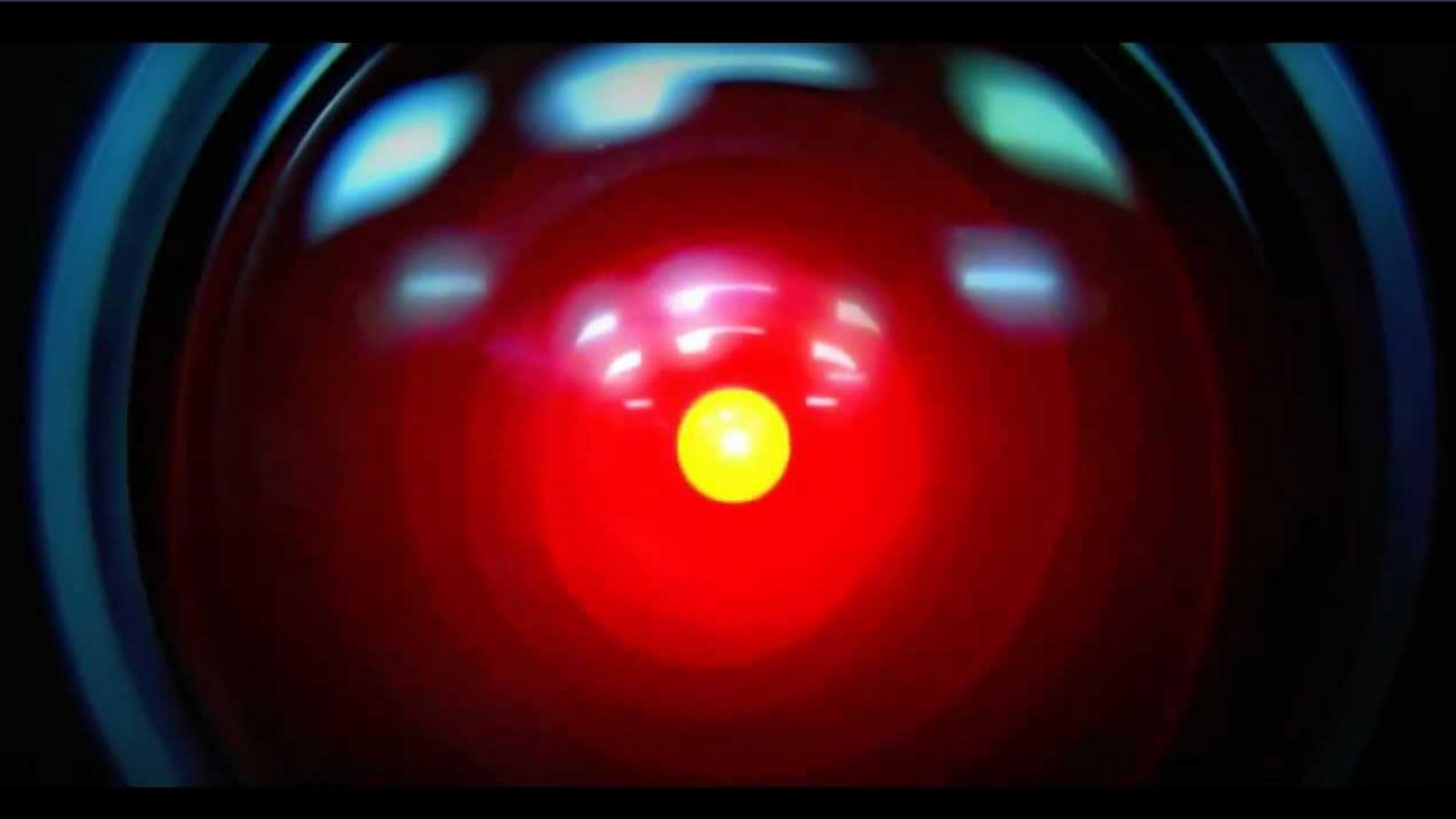
You gotta play to win!



AI, QUANTUM, AND APTS - OH MY!

August 29, 1997

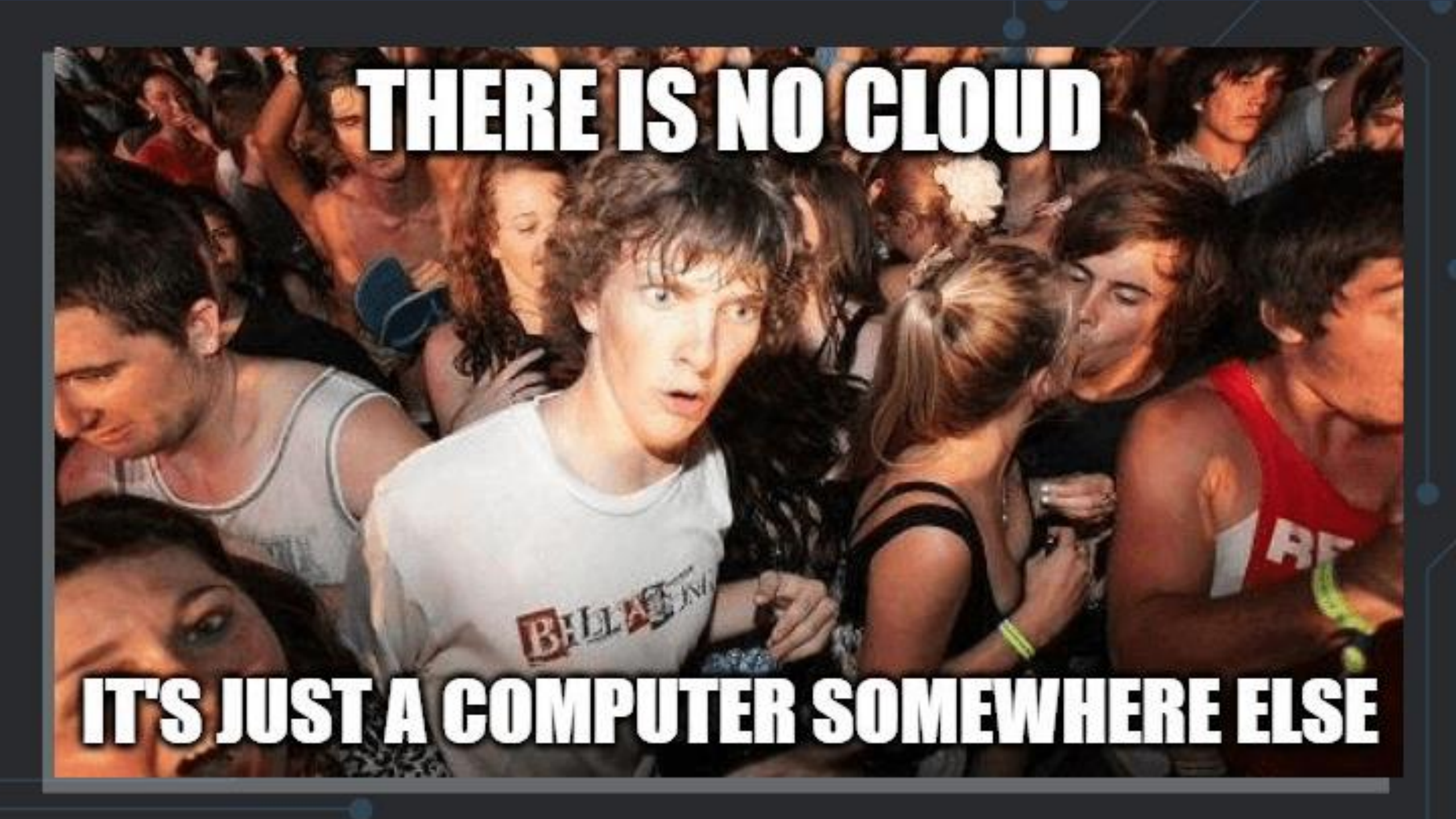
Skynet becomes self-aware





WOPR
WAR OPERATION PLAN RESPONSE

WOPR

A young man with curly brown hair and a wide-eyed, open-mouthed expression of surprise or shock is the central figure. He is wearing a white t-shirt with a red and black logo that partially reads "BILLA". He is surrounded by a dense crowd of people in a dimly lit, warm-toned environment, likely a nightclub or concert. To his left, a man in a white tank top looks down. To his right, a woman with blonde hair in a ponytail is seen from the back, and a man in a red tank top is partially visible. The background is filled with other people, some looking towards the camera and others looking away. The overall atmosphere is one of a crowded, lively event.

THERE IS NO CLOUD

IT'S JUST A COMPUTER SOMEWHERE ELSE

The talent shortage

JUST GRADUATED WITH A CYBERSECURITY
DEGREE AND A DOZEN CERTIFICATIONS...



I WAS TOLD

THERE WOULD BE JOBS



**IF WE'RE GOING TO
KEEP LOWERING THE BAR**

**WE'RE GOING TO HAVE
TO START USING SHOVELS**

**Compliance
does not
equal
Security**



Why do we call it an industry?



MITTEL
RSA
Conference
2019
3400

3300

3200

ing IT together

ManageEngine

Intelligent
Network
Management
Software

Intelligent
Security
Management
Software

Intelligent
Cloud
Management
Software

Intelligent
Data
Management
Software

Intelligent
IT
Management
Software

ManageEngine

Intelligent
Network
Management
Software

Intelligent
Network
Management
Software

Intelligent
Network
Management
Software

Intelligent
Network
Management
Software

Intelligent
Network
Management
Software



What's Your Security Posture?



We think security is achievable

A close-up photograph of a microphone with a black, textured foam windscreen. The microphone is positioned vertically on a white surface that has several circular holes. The background is a solid blue color. The text "Vulnerability Management – Winning or Losing?" is overlaid in large, bold, red font at the bottom of the image.

Vulnerability Management – Winning or Losing?

**So what can or
should we be doing?**

Three Fundamental Problems

- Security is someone else's problem
- If I'm using it, it must be secure
- Technology/Automation solves everything

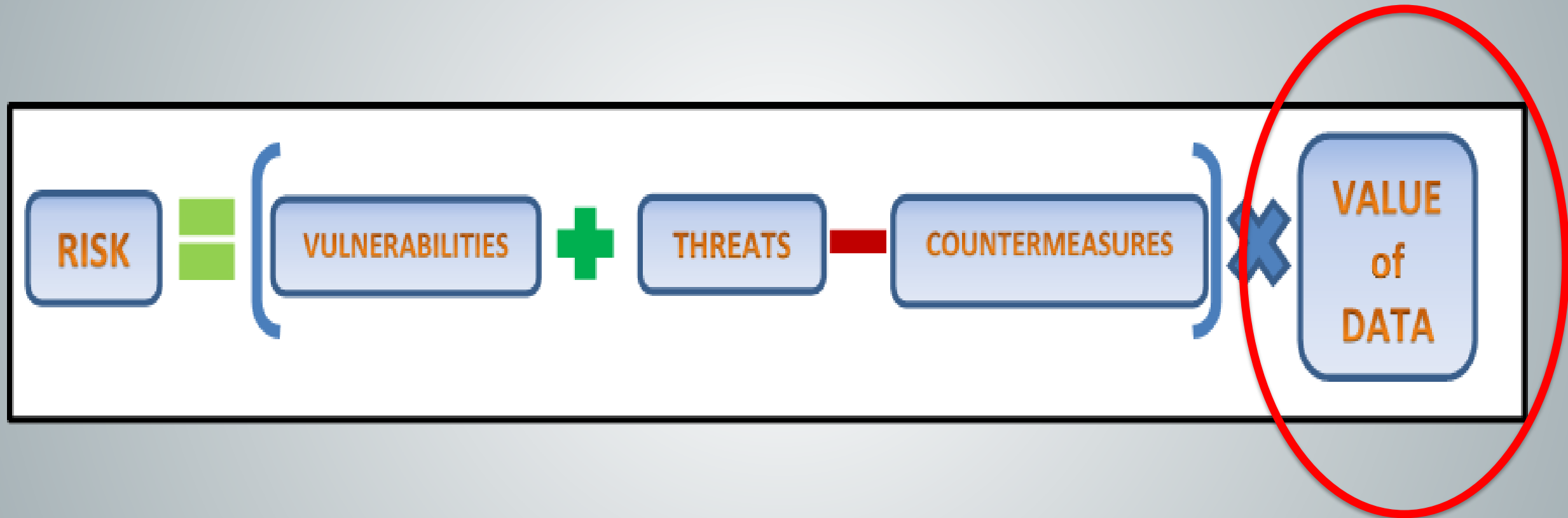
KOBAYASHI MARU

CLASSIFICATION:	Class III Neutronic Fuel Carrier
REGISTRY:	Amber, Tau Ceti IV
MASTER:	Kojiro Vance
CREW:	81
PASSENGERS:	300
DEAD WEIGHT TONNAGE:	147,943 M. T.
CARGO CAPACITY:	97,000 M. T.
LENGTH:	237 m.

~~OPPRESS~~
~~ANARCHY~~

DON'T Tell Me
What To Do!!

Risk-Based Security Model



How Valuable is the Data?



Security-in-Depth



Building a Culture of Security



The components of information security

1. PURPOSE!!!

- People
- Processes
- Technology

Parting Shots

- Technology isn't the solution, it's the problem
- Knowledge and awareness is key
- Security is not a state you achieve
- Security is something you do
- Approach security with a purpose in mind
- Focus on what is valuable and/or requires protection

**STOP BITCHING
START A REVOLUTION™**
WWW.ZENDIK.ORG

#PSA

SecureIdeas
professionally evil®

Jeff Man

Information Security
Evangelist

InfoSec Curmudgeon

Paul's Security Weekly

Executive Director, PCI

Secure Ideas

@MrJeffMan

301-310-4275

jeff@secureideas.com



Question
everything

